

Transport Layer Security

Secure Socket Layer

What is SSL and why is it important?

- SSL is standard technology for securing an internet connection by encrypting data sent between a website and a browser (or between two servers).
- Secure Sockets Layer (SSL) certificates, sometimes called digital certificates.
- It is used to establish an encrypted connection between a browser or user's computer and a server or website.
- It prevents hackers from seeing or stealing any information transferred, including personal or financial data.

WHAT ARE TLS/SSL CERTIFICATES?

- Transport Layer Security (TLS) certificates are most commonly known as SSL, or digital certificates.
- They are the foundation of a safe and secure internet. TLS/SSL certificates secure internet connections by encrypting data sent between your browser, the website you're visiting, and the website server.
- They ensure that data is transmitted privately and without modifications, loss or theft

WHY DO SITES NEED TO USE TLS/SSL CERTIFICATES?

- TLS/SSL certificates are the standard by all major web browsers to ensure a safer internet experience for users.
- Websites secured by TLS/SSL certificates are more trusted by internet users because they encrypt and protect private information transferred to and from their website.
- They also represent, or certify, your website's brand identity.
- So, TLS/SSL certificates are both an identity protection measure for online brands, and a security measure for companies transmitting private data online.

A website that implements SSL/TLS has "HTTPS" in its URL instead of "HTTP."

HTTP vs HTTPS



How does SSL/TLS work?

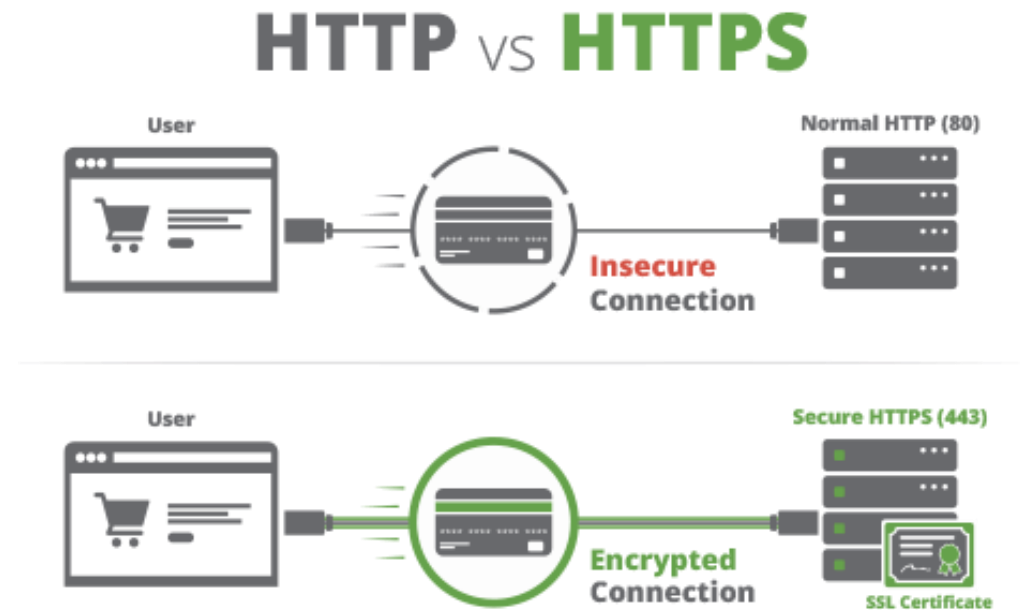
- To, provide a **high degree of privacy**, SSL encrypts data that is transmitted across the web. This means that anyone who tries to intercept this data will only see a garbled mix of characters that is nearly impossible to decrypt.
- SSL initiates an **authentication** process called a handshake between two communicating devices to ensure that both devices are really who they claim to be.
- SSL also digitally signs data to provide **data integrity**, verifying that the data is not tampered with before reaching its intended recipient.

Why is SSL/TLS important?

- Originally, data on the Web was transmitted in plaintext that anyone could read if they intercepted the message. For example, if a consumer visited a shopping website, placed an order, and entered their credit card number on the website, that credit card number would travel across the Internet unconcealed.
- SSL was created to correct this problem and protect user privacy. By encrypting any data that goes between a user and a web server, SSL ensures that anyone who intercepts the data can only see a scrambled mess of characters. The consumer's credit card number is now safe, only visible to the shopping website where they entered it.
- SSL also stops certain kinds of cyber attacks: It authenticates web servers, which is important because attackers will often try to set up fake websites to trick users and steal data. It also prevents attackers from tampering with data in transit, like a tamper-proof seal on a medicine container.

Secure Socket Layer

- A Secure Socket Layer (SSL) is a security protocol **developed by Netscape** in the 1990's for sending information securely (encrypted) over the Internet.
- Once upon a time, websites used SSL only for secure areas of their websites, such as **user login pages or online checkout**. Today, SSL has been deprecated (replaced) by a new standard for online encryption of website traffic known as Transport Layer Encryption.
- Websites used SSL and now **TLS to encrypt all data in motion between the web browser and destination website**. This prevents hackers from intercepting and reading the transmissions.
- You will know you're protected by SSL or TLS whenever you visit a website and your browser URL Bar displays a Lock symbol.
- SSL and TLS accomplish their encryption by use of special digital certificates which tie back to the identity and owner of the company or merchant in question. This allows online shoppers to trust that the website is secure and reliable.
- If you host a website, make sure you purchase a SSL/TLS Certificate from a trusted Certificate issuer.



SSL protocol stack

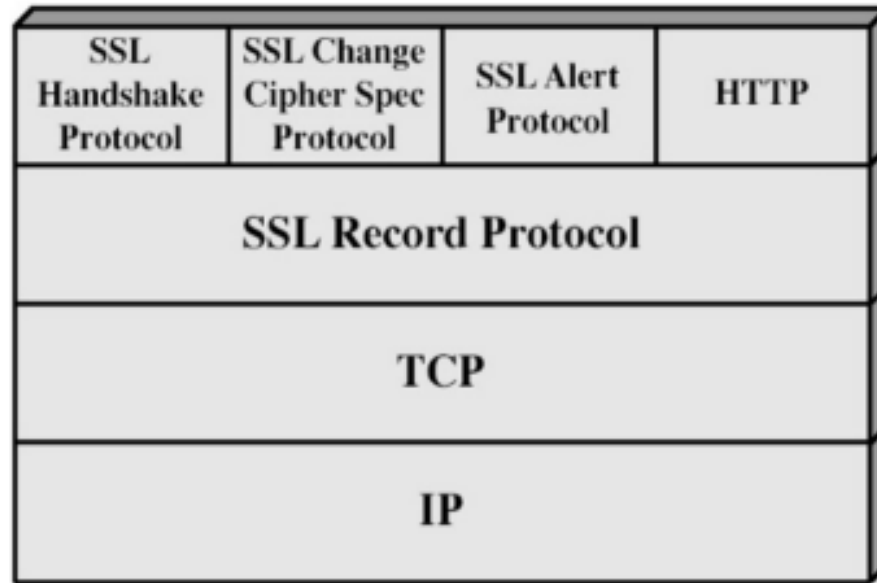


Figure 11.1: SSL protocol stack.

- The SSL record protocol, which is at a lower layer and offers services to these three higher level protocols.
 1. Handshake Protocol.
 2. Change Cipher Spec Protocol.
 3. Alert Protocol.

SSL Record Protocol

- This protocol provides two services for SSL connections:
 - Confidentiality - using conventional encryption.
 - Message Integrity - using a Message Authentication Code (MAC).

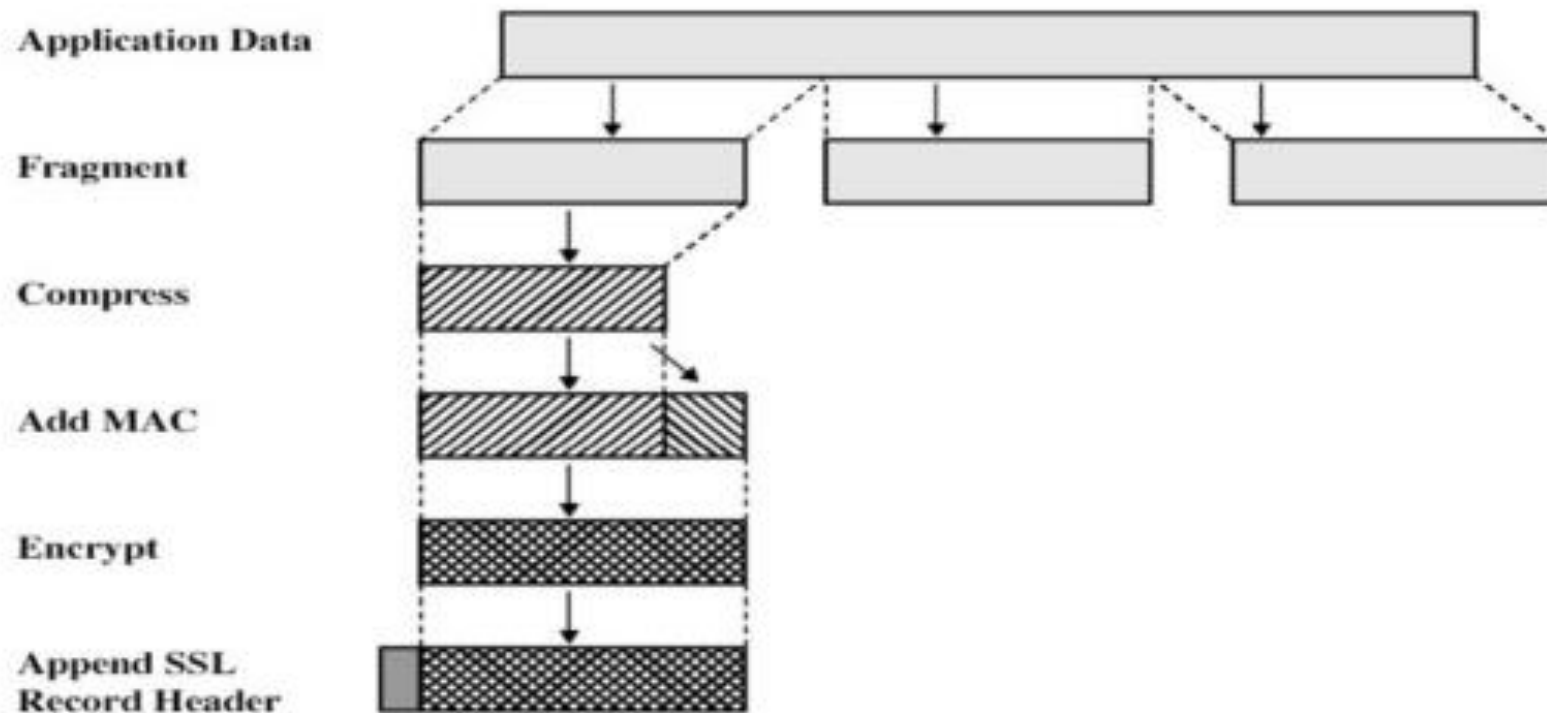


Figure 11.2: SSL Record Protocol Operation.

In order to operate on data the protocol performs the following actions (see figure 11.2):

- It takes an application message to be transmitted and fragments it into manageable blocks. These blocks are $2^{14} = 16,384$ bytes or less.
- These blocks are then optionally compressed which must be lossless and may not increase the content length by more than 1024 bytes.
- A message authentication code is then computed over the compressed data using a shared secret key. This is then appended to the compressed (or plaintext) block.
- The compressed message plus MAC are then encrypted using symmetric encryption. Encryption may not increase the content length by more than 1024 bytes, so that the total length may not exceed $2^{14} + 2048$. A number of different encryption algorithms are permitted.
- The final step is to prepend a header, consisting of the following fields:

- Content type (8 bits) - The higher layer protocol used to process the enclosed fragment.
- Major Version (8 bits) - Indicates major version of SSL in use. For SSLv3, the value is 3.
- Minor Version (8 bits) - Indicates minor version in use. For SSLv3, the value is 0.
- Compressed Length (16 bits) - The length in bytes of the compressed (or plaintext) fragment.

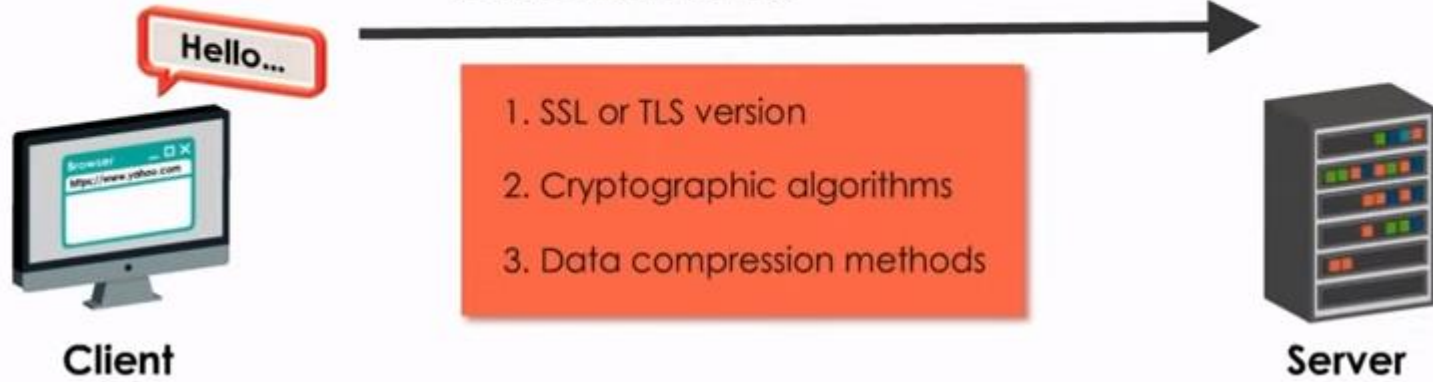
SSL Handshake Protocol

This is the most complex part of SSL and allows the server and client to authenticate each other and to negotiate an encryption and MAC algorithm and cryptographic keys to be used to protect data sent in an SSL record. This protocol is used before any application data is sent. It consists of a series of messages exchanged by the client and server, all of which have the format shown in figure 11.5. Each message has three fields:

1. Type (1 byte): Indicates one of 10 messages such as “hello_request” (see figure 11.4).
2. Length (3 bytes): The length of the message in bytes.
3. Content(≥ 0 byte): The parameters associated with this message such version of SSL being used.



ClientHello



ServerHello







Client

Finished(client)

The finish message is encrypted with the shared secret key-handshake complete.



Server



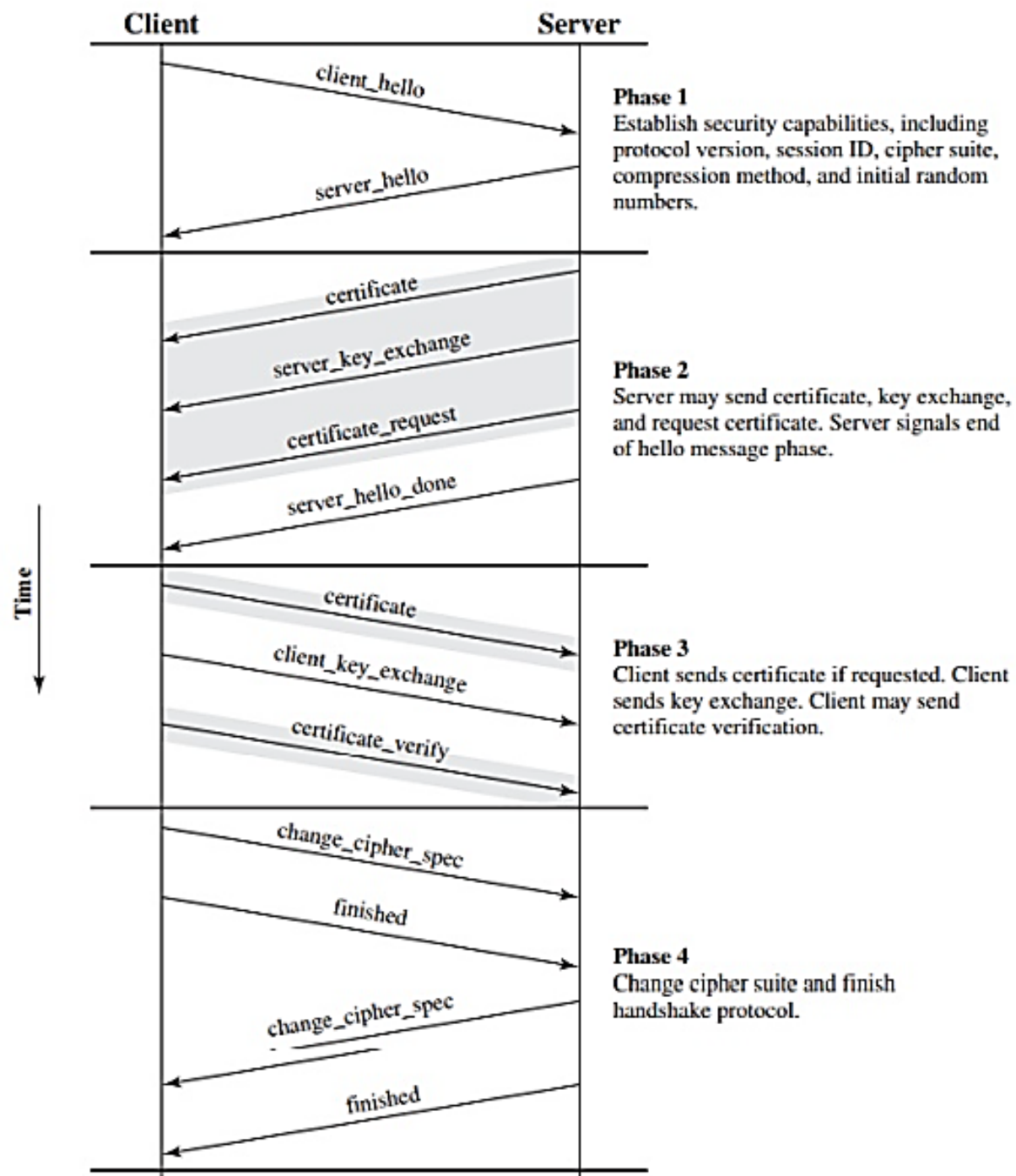
Client

Finished(server)

The finish message is encrypted with the shared secret key-handshake complete.



Server



The Handshake Protocol is shown in figure 11.6. This consists of four phases:

1. Establish security capabilities including protocol version, session ID, cipher suite, compression method and initial random numbers. This phase consists of the `client_hello` and `server_hello` messages which contain the following (this is for the client however it's a little different for the server):
 - Version: The highest SSL version understood by client
 - Random: 32-bit timestamp and 28 byte nonce.
 - Session ID: A variable length session identifier.
 - CipherSuite: List of cryptoalgorithms supported by client in decreasing order of preference. Both key exchange and CipherSpec (this includes fields such as CipherAlgorithm, MacAlgorithm, CipherType, HashSize, Key Material and IV Size) are defined.
 - Compression Method: List of methods supported by client.
2. Server may send certificate, key exchange, and request certificate it also signals end of hello message phase. The certificate sent is one of a chain of X.509 certificates discussed earlier in the course. The `server_key` exchange is sent only if required. A certificate may be requested from the client if needs be by `certificate_request`.
3. Upon receipt of the `server_done` message, the client should verify that the server provided a valid certificate, if required, and check that the `server_hello` parameters are acceptable. If all is satisfactory, the client sends one or more messages

back to the server. The client sends certificate if requested (if none available then it sends a no_certificate alert instead). Next the client sends client_key_exchange message . Finally, the client may send certificate verification.

4. Change cipher suite and finish handshake protocol. The secure connection is now setup and the client and server may begin to exchange application layer data.

Change Cipher Spec Protocol.

- A cipher suite is a set of cryptographic algorithms.
 - The SSL handshake protocol determines how the client and server negotiate which cipher suites they will use.
- The most commonly used cipher suites are:
 - DES (Data Encryption Standard)
 - DSA (Digital Signature Algorithm)
 - KEA (Key Exchange Algorithm)
 - MD5
 - RC2
 - RC4
 - RSA
 - SHA-1 (Secure Hash Algorithm)
 - SKIPJACK
 - Triple DES

SSL Alert Protocol

- This protocol is used to convey SSL-related alerts to the peer entity. Each message in this protocol contains 2 bytes.



- **Warning (level = 1):**
This Alert has no impact on the connection between sender and receiver
- **Fatal Error (level = 2):**
- This Alert breaks the connection between sender and receiver. The connection will be stopped, cannot be resumed but can be restarted.